

LAB GUIDELINES

Lab 20 — Identity & Access Management for Server Administration

Maps to CompTIA Server+ objective **3.3 — Explain important concepts pertaining to identity and access management for server administration** (user accounts, user groups, password policies — length / lockout / enforcement, permissions and access controls — role-based, rule-based, scope-based, segregation of duties, delegation, auditing — user activity, logins, group memberships, deletions, MFA — something you know/have/are, SSO).

Run all commands on <https://killercode.com/playgrounds/scenario/ubuntu>

Required software (free, apt): sudo, libpam-pwquality, passwd, audit tools

```
apt update && apt install -y sudo libpam-pwquality
```

(MFA is its own lab — Lab 21.)

Step 1 — User accounts, groups, and segregation of duties (SoD)

```
# Three roles → three Linux groups (RBAC):
groupadd -f sysops      # full sudo
groupadd -f dbops       # only DB service control
groupadd -f netops      # only firewall + interface control

useradd -m -G sysops alice && echo 'alice:AlicePass!1' | chpasswd
useradd -m -G dbops bob && echo 'bob:BobPass!1' | chpasswd
useradd -m -G netops carol && echo 'carol:CarolPass!1' | chpasswd
id alice; id bob; id carol
```

alice cannot touch firewalls; carol cannot touch the DB. That's **segregation of duties**.

Step 2 — Rule-based + role-based delegation via sudoers

Create one sudoers fragment per role (Server+ 3.3 calls this **delegation**):

```
cat > /etc/sudoers.d/sysops <<'EOF'
%sysops ALL=(ALL:ALL) ALL
EOF

cat > /etc/sudoers.d/dbops <<'EOF'
Cmd_Alias DBCMD = /bin/systemctl start mariadb, \
                  /bin/systemctl stop mariadb, \
                  /bin/systemctl restart mariadb, \
                  /bin/systemctl status mariadb
%dbops ALL=(root) NOPASSWD: DBCMD
EOF

cat > /etc/sudoers.d/netops <<'EOF'
Cmd_Alias NETCMD = /usr/sbin/ufw, /sbin/ip
%netops ALL=(root) NOPASSWD: NETCMD
EOF

chmod 440 /etc/sudoers.d/*
visudo -c
```

Test:

```
sudo -u bob -i bash -c 'sudo systemctl restart mariadb && echo bob-ok'
sudo -u carol -i bash -c 'sudo ufw status && echo carol-ok'
sudo -u carol -i bash -c 'sudo systemctl restart mariadb 2>&1 | head -1' # denied
```

This is **role-based** (group → role) + **rule-based** (Cmd_Alias → rule). **Scope-based** is the LDAP/OU equivalent from Lab 11.

Step 3 — Password policy: length, complexity, lockout, enforcement

Edit /etc/security/pwquality.conf:

```
cat > /etc/security/pwquality.conf <<'EOF'
minlen = 14
minclass = 3      # at least 3 of: lower, upper, digit, special
maxrepeat = 2
dcredit = -1      # require >=1 digit
ucredit = -1      # require >=1 uppercase
lcredit = -1      # require >=1 lowercase
ocredit = -1      # require >=1 other
EOF
```

Lockout via pam_faillock:

```
grep -q pam_faillock /etc/pam.d/common-auth || \
sed -i '1i auth required pam_faillock.so preauth silent deny=5 unlock_time=900' /etc/pam.d/common-auth
echo "auth [default=die] pam_faillock.so authfail deny=5 unlock_time=900" >> /etc/pam.d/common-auth
```

Age enforcement:

```
chage -M 90 -m 1 -W 7 alice      # max 90 days, min 1 day, warn 7 days
chage -l alice
```

Step 4 — Permissions: file ACLs vs. group bits

```
apt install acl
mkdir -p /srv/dbdata && chgrp dbops /srv/dbdata && chmod 2770 /srv/dbdata
setfacl -m g:netops:r-x /srv/dbdata      # netops read-only
getfacl /srv/dbdata
```

Server+ 3.3 lists **permissions and access controls** alongside RBAC/rule-based — these are the on-disk enforcers.

Step 5 — Auditing the 4 things the exam names

Audit target	Where to find it
User activity	`auditd` rules + `last`, `lastcomm`
Logins	`/var/log/auth.log`, `last`, `lastb` (bad logins)
Group memberships	`getent group sysops dbops netops`
Deletions	`auditd -w` on sensitive paths

```
last | head
lastb | head 2>/dev/null
getent group sysops dbops netops
grep -E 'useradd|userdel|groupmod' /var/log/auth.log | tail
```

Step 6 — MFA factor categories (preview for Lab 21)

Factor	Example
Something you know	Password, PIN
Something you have	TOTP app, FIDO2 key, smart card
Something you are	Fingerprint, iris, face

Implementation is Lab 21.

Step 7 — Single Sign-On (SSO)

SSO = one set of credentials authenticates to many services. On Linux servers this typically means:

- **Kerberos** (with Active Directory or FreeIPA) for SSH and file shares.
- **SAML / OIDC** for web apps.
- **PAM + SSSD + LDAP** is the binding layer (Lab 11).

SSO benefits: fewer passwords, central revocation, central audit. SSO risks: one compromised account opens many services → must combine with MFA.

Free online tools

- **NIST SP 800-63B (auth guidelines)** — <https://pages.nist.gov/800-63-3/sp800-63b.html>
- **sudoers manual** — <https://www.sudo.ws/docs/man/sudoers.man/>
- **pam_pwquality docs** — <https://man7.org/linux/man-pages/man5/pwquality.conf.5.html>

What you learned

- RBAC, rule-based, and scope-based delegation all in one sudoers exercise.
- Real password length + complexity + lockout + age enforcement.
- Group/ACL permission layering.
- The four audit targets the exam names and where to find each on Linux.
- The three MFA factor categories and the SSO concept that wraps them.